Policy 9 – Access Control & Least Privilege

1. Table of Contents

1 Document Content Page

2 Policy Objectives and Scope

2.1 Purpose

2.2 Scope

2.3 Joiner-Mover-Leaver (JML) Process

2.4 Role-Based Access Control (RBAC)

2.5 Privilege Elevation & Approval

2.6 Periodic Access Review

3 Policy Compliance

3.1 Compliance Measurement

3.2 Exceptions

3.3 Non-Compliance

3.4 Continual Improvement

2. Policy Objectives and Scope

2.1 Purpose – Ensure users receive only the minimum access necessary and that access adjusts promptly with role changes.

2.2 Scope – All workforce accounts, service accounts, and system roles across SaaS, IaaS, and on-prem resources.

2.3 Joiner-Mover-Leaver (JML) Process

- Provision access via ticket with manager approval.
- Modify privileges within 48 h of role change.
- Disable or delete accounts by end of final workday.

2.4 Role-Based Access Control (RBAC)

- Define standard roles per system (e.g., Admin, User, Read-Only).

- Assign users to roles; avoid direct entitlements wherever possible.

2.5 Privilege Elevation & Approval

- Temporary admin rights require documented business justification and auto-expire ≤ 24 h.
- All permanent admin assignments approved by senior management.

2.6 Periodic Access Review

- System owners review user lists at least quarterly; remove stale or excessive rights.
- Document review date, reviewers, and actions.

3. Policy Compliance

3.1 Compliance Measurement – Quarterly review shows ≤ 2 % orphaned accounts; all admin rights have approval record.

3.2 Exceptions – Emergency access allowed max 8 h; log reason and close in next review.

3.3 Non-Compliance – Unapproved elevated access or dormant accounts >30 days escalated to management and remediated within one week.

3.4 Continual Improvement – Incorporate review findings to refine role definitions and automate provisioning.